

Fiches de prérequis

Durcissement Linux et Windows — 21 h — Cinquième année



Fiche 1 — Administration Linux courante

À maîtriser : naviguer, lire une configuration, gérer un service, installer un paquet.

Arborescence utile

/etc la configuration · /var/log les journaux · /srv et /opt les données de service · /proc et /sys les interfaces vers le noyau

Services

`systemctl status | start | stop | enable | disable`

Retenez la différence entre **actif** (le service tourne maintenant) et **activé** (il redémarrera au prochain démarrage). La confusion est très fréquente, et le script de correction du TP (travaux pratiques) teste les deux séparément.

`journalctl -u <service>` pour les journaux d'un service, `-b` pour le démarrage courant, `-p err` pour les erreurs seules.

Paquets

`apt update`, `apt install`, `apt purge` — **APT** (Advanced Package Tool)

`purge` n'est pas `remove` : `purge` supprime aussi les fichiers de configuration.

Permissions

Savoir lire une sortie `ls -l`, la notation octale, `chmod`, `chown`, et reconnaître les bits spéciaux **SUID** (Set User ID), **SGID** (Set Group ID) et sticky.

Réseau

`ss -tlnp` liste ce qui écoute avec le processus associé. `netstat` est obsolète, ne l'utilisez plus.

Édition en console

`nano` suffit largement. Savoir malgré tout sortir de `vi` évite des situations pénibles.

📋 **Auto-test.** Expliquez la différence entre `systemctl is-active` et `systemctl is-enabled`, puis donnez la commande qui liste tous les ports en écoute avec le processus qui les tient.

Fiche 2 — Espace utilisateur, espace noyau, appels système

À maîtriser : savoir ce qu'est un appel système et pourquoi c'est la frontière qui compte.

Un processus ne parle jamais directement au matériel. Il demande au noyau, par un appel système : `open`, `read`, `write`, `execve`, `clone`.

La bibliothèque C enveloppe ces appels. Votre `fopen()` finit en `open()`.

À faire une fois avant le cours

```
strace -f -e trace=openat ls
```

Vous verrez les appels système d'un programme trivial. Cette manipulation change la compréhension du bloc sur le noyau, en séance 3. Ne l'ignorez pas.

Notion de privilège

Le code du noyau s'exécute sans restriction : il n'y a rien au-dessus de lui. C'est ce qui rend une vulnérabilité noyau si grave, et c'est le point de départ de toute la séance 3.

Compilation

```
gcc -o prog prog.c — GCC (GNU Compiler Collection)
```

Savoir compiler un fichier C d'une dizaine de lignes suffit pour l'objectif bonus du TP.

❏ **Auto-test.** Combien d'appels `openat` un simple `ls` effectue-t-il sur votre machine, et pourquoi autant ?

Fiche 3 — Réseau, le strict nécessaire

Modèle client-serveur, port d'écoute, socket.

La distinction qui compte

Écouter sur 127.0.0.1 et écouter sur 0.0.0.0 ne sont pas la même chose. C'est toute la différence entre un service exposé et un service inaccessible depuis l'extérieur. Beaucoup de « vulnérabilités » disparaissent en changeant cette seule valeur.

Ports rencontrés dans le module

Port	Service
22	SSH (Secure Shell)
23	telnet, obsolète et en clair
80 / 443	HTTP / HTTPS (HyperText Transfer Protocol, Secure)
111	rpcbind — RPC (Remote Procedure Call)
139 / 445	SMB (Server Message Block)
3389	RDP (Remote Desktop Protocol)
8080	le service métier de vos TP

Politique par défaut d'un pare-feu

Soit vous acceptez tout puis interdisez au cas par cas, soit vous refusez tout puis autorisez explicitement. Seule la seconde approche est défendable, et c'est celle qui sera vérifiée dans le TP.

Sous Linux, `nftables` remplace `iptables`. `ufw` (Uncomplicated FireWall) est une surcouche acceptable.

Vérifiez toujours une exposition depuis l'extérieur de la machine, jamais depuis la machine elle-même.

- ❏ **Auto-test.** Un service écoute sur 127.0.0.1:8080 et le pare-feu est complètement désactivé. Est-il joignable depuis le réseau ?

Fiche 4 — Windows pour administrateurs

À maîtriser : naviguer dans la configuration Windows sans passer par l'interface graphique.

Registre

Ruches **HKLM** (HKEY_LOCAL_MACHINE) et **HKCU** (HKEY_CURRENT_USER), notion de clé et de valeur, types **DWORD** (Double Word — entier sur 32 bits) et String.

Get-ItemProperty et Set-ItemProperty pour les manipuler.

PowerShell

Convention verbe-nom. Get-Command, Get-Help, Get-Member.

Le point qui change tout : une commande PowerShell renvoie des **objets**, pas du texte. Get-LocalUser | Where-Object { \$_.Enabled } filtre sur une propriété, pas sur une chaîne de caractères.

Consoles à connaître

secpol.msc stratégie de sécurité locale · gpedit.msc stratégie de groupe locale, qui édite des **GPO** (Group Policy Object — objet de stratégie de groupe) · eventvwr.msc observateur d'événements · services.msc · taskschd.msc tâches planifiées

Ligne de commande

secedit /export · auditpol /get /category:* · icacls · net accounts · sc.exe query

Piège à connaître dès maintenant

Les noms de catégories d'auditpol et les noms de groupes locaux sont **traduits selon la langue du système**. Un script écrit sur un Windows anglais échouera sur un Windows français. Préférez les **SID** (Security Identifier — identifiant de sécurité), qui sont invariants : S-1-5-32-544 désigne le groupe des administrateurs dans toutes les langues.

Enfin : PowerShell doit être lancé **en administrateur** pour l'essentiel du TP 2.



Auto-test. Donnez la commande PowerShell qui liste les comptes locaux activés dont le mot de passe n'expire jamais.

Fiche 5 — Hachage, chiffrement, signature

Fiche courte mais nécessaire : la confusion sur ces trois notions est présente jusque dans les descriptifs de cours.

	Ce que ça fait	Réversible	Où dans le module
Hachage	Produit une empreinte de taille fixe	Non	Mots de passe dans <code>/etc/shadow</code> , base AIDE
Chiffrement	Protège la confidentialité	Oui, avec la clé	LUKS, BitLocker
Signature ou MAC	Prouve l'origine et l'intégrité	Sans objet	Signature des paquets APT, signature SMB

AIDE (Advanced Intrusion Detection Environment) · **LUKS** (Linux Unified Key Setup) · **MAC** ici signifie Message Authentication Code — code d'authentification de message, à ne pas confondre avec le Mandatory Access Control vu en séance 3.

Trois points à retenir

Un mot de passe n'est pas chiffré dans `/etc/shadow`. Il est haché, avec un sel. Le sel empêche les tables précalculées. Il n'empêche pas de tester les mots de passe fréquents un par un.

Le chiffrement de disque protège une machine éteinte. Il n'apporte rien contre un attaquant distant sur un système allumé — c'est-à-dire la situation de tout le module.

La majorité des protections étudiées ici ne relèvent d'aucune des trois catégories. ASLR (Address Space Layout Randomization), seccomp, AppArmor, capabilities, règles ASR (Attack Surface Reduction) : ce sont des restrictions d'exécution. Ni du chiffrement, ni du contrôle d'accès.

- ❏ **Auto-test.** Votre serveur est chiffré avec LUKS et un attaquant obtient un shell root à distance pendant qu'il tourne. Que lui coûte le chiffrement ?

Glossaire des sigles du module

Sigle	Développé
ACL	Access Control List — liste de contrôle d'accès
AD	Active Directory
AIDE	Advanced Intrusion Detection Environment
ANSSI	Agence nationale de la sécurité des systèmes d'information
APT	Advanced Package Tool
ASLR	Address Space Layout Randomization — randomisation de l'espace d'adressage
ASR	Attack Surface Reduction — réduction de la surface d'attaque
CFI	Control Flow Integrity — intégrité du flot de contrôle
CIS	Center for Internet Security
DAC	Discretionary Access Control — contrôle d'accès discrétionnaire
DISA STIG	Defense Information Systems Agency — Security Technical Implementation Guide
GPO	Group Policy Object — objet de stratégie de groupe
HKLM / HKCU	HKEY_LOCAL_MACHINE / HKEY_CURRENT_USER
LAPS	Local Administrator Password Solution
LSASS	Local Security Authority Subsystem Service
LUKS	Linux Unified Key Setup
MAC	Mandatory Access Control, ou Message Authentication Code selon le contexte
MIC	Mandatory Integrity Control
NX	No eXecute — interdiction d'exécution
OU	Organizational Unit — unité d'organisation
PAM	Pluggable Authentication Modules
PIE	Position Independent Executable
PPL	Protected Process Light
RDP	Remote Desktop Protocol
RELRO	RELocation Read-Only
SELinux	Security-Enhanced Linux
SID	Security Identifier — identifiant de sécurité
SMB	Server Message Block
SSH	Secure Shell
SUID / SGID	Set User ID / Set Group ID
TGT / TGS	Ticket Granting Ticket / Ticket Granting Service
UAC	User Account Control — contrôle de compte d'utilisateur
UID / GID	User Identifier / Group Identifier
WDAC	Windows Defender Application Control